TP EBIOS Risk Manager

Dossier de synthèse

Analyse des risques de la plateforme cloud ERP/CRM de Rhénalis SAS

Organisation étudiée : Rhénalis SAS, PME de distribution B2B de matériel électrique

Méthode : EBIOS Risk Manager (ANSSI), ateliers 1 à 5

Groupe : Kleiton KITANI, Ryan AMORY

Formation : BUT 3 Réseaux & Télécommunications, parcours Cybersécurité - UHA / IUT de Colmar

Date : 21 octobre 2026

Livrables associés : Classeur EBIOS RM complété ; support de restitution orale. Journal d'hypothèses en annexe A

*Toutes les données de ce dossier sont fictives. Les éléments ajoutés par le groupe sont signalés comme hypothèses **[H]**, déclarations **[D]** ou informations manquantes **[M]** ; seuls les éléments fournis par le sujet sont des faits établis **[F]**.*

Sommaire

1. Synthèse pour la direction 3
1.1 Les cinq risques retenus 3
1.2 Les neuf actions prioritaires (P1) 3
1.3 Budget et décisions attendues 4
2. Cadrage, périmètre et méthode 5
2.1 Objet de l'étude 5
2.2 Périmètre et exclusions 5
2.3 Participants et cadre temporel 5
2.4 Méthode et échelles 5
3. Atelier 1 - Valeurs métier, événements redoutés et socle 6
3.1 Valeurs métier et biens supports 6
3.2 Événements redoutés et gravité 6
3.3 Socle de sécurité : écarts constatés 7
4. Atelier 2 - Sources de risque et objectifs visés 8
4.1 Justification des exclusions 8
5. Atelier 3 - Écosystème et scénarios stratégiques 10
5.1 Cotation des parties prenantes 10
5.2 Justification des cotations 11
5.3 Scénarios stratégiques 11
5.4 Mesures sur l'écosystème 12
6. Atelier 4 - Scénarios opérationnels et vraisemblance 13
6.1 Déroulement des cinq scénarios 13
6.2 Graphes d'attaque 13
6.3 Cotation de la vraisemblance 15
7. Atelier 5 - Traitement du risque 16
7.1 Synthèse des risques 16
7.2 Plan de traitement du risque 16
7.3 Risques résiduels 18
7.4 Cadre de suivi 19
8. Limites de l'analyse 20
Annexe A - Journal d'hypothèses 21
Annexe B - Correspondance avec le classeur 23

1. Synthèse pour la direction

Deux risques ressortent comme élevés et mettent en jeu la continuité de Rhénalis : la perte définitive des données de gestion à la suite d'un rançongiciel, soit en passant par l'infogérant (R1), soit à partir du poste d'un salarié (R3). Les deux reposent sur les mêmes faiblesses : accès d'administration sans double authentification, compte administrateur partagé, sauvegardes sans test de restauration documenté ni copie hors ligne, absence de supervision. Ces faiblesses sont des hypothèses de travail, à vérifier en priorité.

Les trois autres risques sont modérés : indisponibilité de l'ERP par la chaîne de maintenance de l'éditeur (R2), détournement de paiements clients (R4) et départ d'un commercial avec le fichier clients (R5).

1.1 Les cinq risques retenus

Risque	Description	Gravité	Vrais.	Niveau initial	Niveau résiduel
R1	Perte définitive des données de gestion, via l'infogérant	G4	V3	Elevé	Modéré
R2	ERP indisponible plus d'une semaine, via la maintenance de l'éditeur	G3	V2	Modéré	Significatif
R3	Perte définitive des données de gestion, à partir du poste d'un salarié	G4	V3	Elevé	Modéré
R4	Détournement de paiements clients (fraude au RIB)	G3	V3	Modéré	Modéré
R5	Départ d'un commercial avec le fichier clients et les tarifs	G3	V3	Modéré	Modéré

Niveau de risque = croisement gravité × vraisemblance, selon la matrice de la feuille Métriques du classeur.

1.2 Les neuf actions prioritaires (P1)

N°	Action	Propriétaire	Échéance	Coût estimé [H]
M10	Courrier aux grands comptes : Rhénalis ne change jamais de RIB par e-mail ; en cas de doute, rappeler le numéro habituel	Thomas Weber (DAF)	30/11/2026	0 €
M18	Double validation par le DAF de toute modification de RIB dans l'ERP (clients et fournisseurs), avec traçabilité	Thomas Weber (DAF)	30/11/2026	0 €
M06	Authentification multifacteur sur tous les accès distants (administration, VPN nomades), sur la console d'administration IaaS et sur la messagerie	Sophie Haas (resp. informatique)	31/12/2026	4 k€/an
M09	Restreindre l'export du CRM à la direction commerciale, revue trimestrielle des droits, blocage des supports USB sur les portables	Julien Roth (dir. commercial)	31/12/2026	1 k€
M01	Avenant sécurité au contrat d'infogérance : MFA, comptes nominatifs, journalisation, correctifs des serveurs sous 30 jours, notification d'incident sous 24 h, droit d'audit annuel	Thomas Weber (DAF)	31/01/2027	2 k€ (juridique)
M15	Sauvegarde immuable externalisée chez un tiers distinct de l'infogérant, test de restauration trimestriel	Sophie Haas (resp. informatique)	31/01/2027	6 k€/an
M05	Sensibilisation des salariés à l'hameçonnage et campagne d'exercice semestrielle	Sophie Haas (resp. informatique)	31/01/2027	3 k€/an
M12	Déployer une solution de détection et réponse (EDR) sur les postes et les serveurs	Sophie Haas (resp. informatique)	28/02/2027	8 k€/an
M07	Bastion d'administration avec comptes nominatifs et enregistrement des sessions ; suppression du compte admin partagé	Sophie Haas (pilotage) / InfoGest	30/04/2027	15 k€ + 5 k€/an

Ces actions visent d'abord les deux risques élevés : pour R1, l'avenant au contrat d'infogérance (M01) et le bastion nominatif (M07) ; pour R3, la sensibilisation à l'hameçonnage (M05) et la détection sur les postes (M12) ; pour les deux, la double authentification (M06) et la sauvegarde immuable testée (M15). S'y ajoutent trois mesures rapides et presque sans coût (M09, M10, M18). La vérification de l'hébergeur (M04) passe en P2 : c'est un contrôle préalable, qui ne réduit aucun risque à lui seul. La sauvegarde immuable testée (M15) supprime à elle seule la perte définitive des données, ce qui fait passer la gravité de R1 et R3 de G4 à G3. Contre la fraude au

RIB, le courrier aux grands comptes (M10) et la double validation des RIB dans l'ERP (M18) réduisent le risque sans le supprimer, car c'est le client qui effectue le paiement.

1.3 Budget et décisions attendues

Le plan complet compte **19 actions sur 12 mois**. Ordre de grandeur **[H]** : environ **33 k€ d'investissement** et **51 à 56 k€ par an** de fonctionnement, soit environ 0,4 % du chiffre d'affaires supposé (22 M€) la première année, puis 0,25 % par an.

- Valider le plan de traitement du risque et son budget.
- Mandater le DAF pour renégocier le contrat d'infogérance (M01) avant fin janvier 2027.
- Désigner formellement un référent sécurité et instaurer un comité sécurité trimestriel.
- Accepter explicitement les risques résiduels : R1, R3, R4 et R5 restent modérés après traitement.

2. Cadrage, périmètre et méthode

2.1 Objet de l'étude

L'étude porte sur la capacité de Rhénalis à **vendre, livrer, facturer et tenir sa comptabilité** grâce à sa plateforme cloud hébergeant l'ERP et le CRM [F] : postes de travail, serveurs d'application, base de données, annuaire, sauvegardes et prestataire d'infogérance [F]. Rhénalis est une PME d'environ 90 salariés et 22 M€ de chiffre d'affaires [H], implantée à Colmar et Mulhouse [H], qui distribue du matériel électrique à des professionnels [H].

2.2 Périmètre et exclusions

Dans le périmètre	Hors périmètre, et pourquoi
ERP (ventes, achats, stocks, facturation, comptabilité) et CRM	Infrastructure interne du fournisseur de messagerie : elle relève du fournisseur ; seul l'usage de la messagerie par Rhénalis est étudié
Messagerie (SaaS), bien support de VM1 et VM3 : commandes et factures transitent par e-mail	Hébergement physique des serveurs : relève de l'hébergeur IaaS, traité comme partie prenante
Serveurs d'application, base de données, annuaire, infrastructure IaaS	Paie et RH : logiciel séparé, sans interface avec l'ERP [H]
Sauvegardes, gérées par l'infogérant	Site web vitrine : hébergé ailleurs, sans prise de commande en ligne [H]
Environ 75 postes accédant à l'ERP/CRM, dont 12 portables nomades [H]	Équipements d'entrepôt : faible dépendance à la plateforme [H]
Accès VPN du siège, VPN nomade et accès d'administration de l'infogérant	Téléphonie et sécurité physique des locaux : hors objet d'étude

2.3 Participants et cadre temporel

Direction : Claire Muller (DG). Métier : Thomas Weber (DAF) et Julien Roth (directeur commercial). DSI et RSSI de fait : Sophie Haas, responsable informatique. Architecte technique : InfoGest Services, l'infogérant. Le groupe d'étudiants tient le rôle de conseil SSI et assure la veille sur la menace. Ces personnes sont fictives [H] ; elles sont nommées parce que le plan de traitement exige un propriétaire identifié pour chaque action.

Cycle stratégique (ateliers 1, 2, 3 et 5) : révision tous les **3 ans**, ou en cas de changement majeur - nouvel ERP, changement d'infogérant ou d'hébergeur. Cycle opérationnel (atelier 4 et suivi du plan) : révision **annuelle**, ou après tout incident significatif. Horizon du plan de traitement : **12 mois**.

2.4 Méthode et échelles

- Méthode EBIOS Risk Manager de l'ANSSI, conduite avec le classeur modèle officiel et les fiches méthodes des ateliers 1 à 5.
- Gravité de G1 à G4, vraisemblance de V1 à V4, niveau de risque issu de la matrice de la feuille Métriques (Faible, Significatif, Modéré, Élevé). Les échelles ont été relues et validées par le groupe avant toute cotation.
- Vraisemblance estimée par la **méthode expresse**, c'est-à-dire une cotation directe de chaque scénario, que le guide du TP recommande pour un premier exercice. Conformément à la méthode, elle s'évalue en supposant que la source de risque passe à l'acte.
- Échelle des niveaux de risque de la feuille Métriques, du plus haut au plus bas : **Élevé (4) > Modéré (3) > Significatif (2) > Faible (1)**. « Significatif » est donc un niveau plus bas que « Modéré ».
- Chaque information porte un statut : fait établi [F], déclaration [D], hypothèse [H] ou information manquante [M]. Le journal complet des 23 hypothèses figure en annexe. Aucune information n'a été recueillie auprès de personnes réelles : ce qui serait une déclaration dans une mission réelle est noté [H], avec l'interlocuteur auprès de qui la recueillir.

3. Atelier 1 - Valeurs métier, événements redoutés et socle

L'atelier 1 fixe ce qui doit être protégé, ce que l'on cherche à éviter, et l'état réel des protections existantes.

3.1 Valeurs métier et biens supports

Valeur métier	Nature	Principaux biens supports	Responsable
VM1 - Prise et traitement des commandes	Processus	Module Ventes de l'ERP, postes de l'ADV, serveurs d'application (IaaS)	J. Roth (interne)
VM2 - Fichier clients et prospects	Information	Application CRM, portables des commerciaux	J. Roth (interne)
VM3 - Facturation et recouvrement	Processus	Module Facturation, plateforme de dématérialisation, postes comptabilité	T. Weber (interne)
VM4 - Données comptables et financières	Information	Base de données ERP/CRM, système de sauvegarde	T. Weber (interne)
VM5 - Gestion des stocks et approvisionnements	Processus	Modules Stocks et Achats, postes de l'entrepôt	Resp. logistique [M]

Quatre biens supports sont transverses à toutes les valeurs métier, donc à fort effet de levier pour un attaquant : l'annuaire, la base de données, les sauvegardes et l'accès distant d'administration. Tous sont gérés par l'infogérant.

La feuille Missions est complétée par six biens supports utilisés dans les scénarios opérationnels : la **messagerie** (SaaS), par laquelle transitent commandes et factures (VM1, VM3) ; les **postes de la comptabilité**, la **console d'administration IaaS**, l'**accès de télémaintenance de l'éditeur**, le **personnel** (utilisateurs et administrateurs, point d'entrée de SO3 à SO5) et les **liaisons VPN** (site à site et nomades).

3.2 Événements redoutés et gravité

Valeur métier	Événement redouté	Impact principal	Besoin D-I-C-T	Gravité
VM1	Impossibilité de prendre et traiter les commandes pendant plus d'une semaine (ERP indisponible, par exemple après un chiffrement par rançongiciel)	Arrêt d'environ 70 % des ventes, soit ~300 k€ de CA par semaine (70 % × 22 M€ / 52).	D3 Le mode dégradé ne tient qu'une journée (H03)	G3
VM1	Altération des commandes en cours (quantités, prix, adresses de livraison modifiés)	Erreurs de livraison et de facturation, retours et litiges, temps de contrôle manuel.	I3 Une altération doit être connue et récupérable	G2
VM2	Vol et divulgation du fichier clients et prospects (exfiltration puis revente ou publication)	Violation de données personnelles : notification à la CNIL sous 72 h, sanction possible.	C3 Accès réservé à la direction commerciale	G3
VM3	Interruption de l'émission des factures et du suivi des encaissements pendant plus de 2 semaines	Retard d'encaissement d'environ 850 k€ (2 semaines de CA), tension de trésorerie.	D2 Rattrapage possible : une semaine tenable	G2
VM3	Modification frauduleuse des coordonnées bancaires sur les factures émises (fraude au RIB)	Paiements clients détournés vers le compte de l'attaquant, potentiellement plusieurs centaines de k€ avant détection.	I4 L'intégrité du RIB doit être garantie	G3
VM4	Perte définitive des données comptables et de gestion (base de données chiffrée ou détruite, sauvegardes inutilisables)	Impossible de reconstituer les comptes clients, les encours, les stocks et la comptabilité.	I4 + T4 Intégrité garantie et traçabilité légale (conservation 10 ans)	G4
VM5	Indisponibilité de la gestion des stocks et des commandes fournisseurs pendant plus de 3 jours	Ruptures de stock, réapprovisionnements bloqués, inventaire manuel des 2 dépôts.	D2 Inventaire manuel possible quelques jours ; au-delà d'une semaine, ruptures	G2

Besoin D-I-C-T : niveau de besoin de la feuille Métriques (D = disponibilité, I = intégrité, C = confidentialité, T = traçabilité), de 1 à 4. Pour VM5, le seuil de 3 jours se situe entre deux niveaux de l'échelle : D2 est retenu car un inventaire manuel permet de tenir quelques jours.

Un seul événement est coté **G4** : la perte définitive des données comptables et de gestion, qui empêcherait de reconstituer les comptes clients, les encours et la comptabilité, et placerait la société en situation de survie. Cette cotation dépend directement de H07 et H08 : aucun test de restauration n'est documenté (information manquante) et les sauvegardes n'ont pas de copie hors ligne (hypothèse). Si une sauvegarde immuable testée existait, cet événement redescendrait à G3.

Les montants cités dans les impacts découlent du chiffre d'affaires supposé de 22 M€ (H01) : ce sont des ordres de grandeur, pas des chiffres constatés.

3.3 Socle de sécurité : écarts constatés

Treize écarts ont été relevés sur six référentiels. Ils constituent la base des cotations de vraisemblance de l'atelier 4 et l'essentiel du plan de traitement de l'atelier 5.

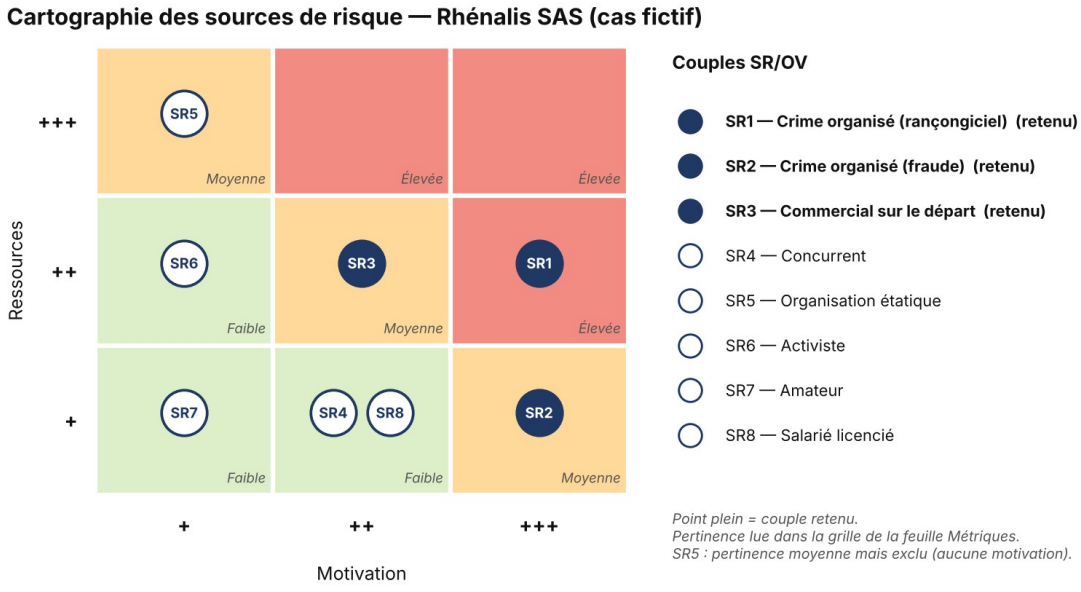
Référentiel	État	Écart	Statut
Guide d'hygiène informatique ANSSI	Partiellement appliqué	Pas d'authentification multifacteur sur les accès distants d'administration (VPN de l'infogérant) ni sur la messagerie	H04
Guide d'hygiène informatique ANSSI	Partiellement appliqué	Compte administrateur de domaine partagé entre les techniciens de l'infogérant, non nominatif	H05
Guide d'hygiène informatique ANSSI	Partiellement appliqué	Aucun test de restauration documenté ; pas de copie hors ligne ou immuable	H06, H07, H08
Guide d'hygiène informatique ANSSI	Partiellement appliqué	Pas de solution de détection sur les postes (EDR), antivirus classique uniquement	H09
Guide d'hygiène informatique ANSSI	Non appliqué	Pas de journalisation centralisée ni de supervision de sécurité	H11
Guide d'hygiène informatique ANSSI	À vérifier	Application mensuelle des correctifs sur les postes supposée, sans preuve	H10
Guide d'hygiène informatique ANSSI	Non appliqué	Pas de politique de sécurité (PSSI) ni de plan de continuité et de reprise (PCA/PRA)	H12
Guide d'hygiène informatique ANSSI	Partiellement appliqué	Droits d'accès au CRM trop larges : tous les commerciaux peuvent exporter l'ensemble du fichier clients ; aucun contrôle des exports ni des supports USB	H19, H21
RGPD (règlement UE 2016/679)	Partiellement appliqué	Registre des traitements incomplet pour le CRM ; pas de procédure de notification de violation à la CNIL sous 72 h	H16
Code de commerce et Livre des procédures fiscales	Appliqué sous réserve	La conservation légale repose sur des sauvegardes sans test de restauration documenté	H07
Contrat d'infogérance InfoGest Services	Partiellement appliqué	Aucune clause de sécurité : ni exigences techniques, ni droit d'audit, ni délai de notification d'incident	H13
Contrat d'hébergement IaaS	À vérifier	Niveau de qualification ou de certification de l'hébergeur inconnu (SecNumCloud ou autre)	H14
Contrôle interne (procédures financières)	Non appliqué	Aucune procédure de vérification des changements de RIB (ni contre-appel, ni double validation) ; clients jamais informés du risque de fraude	H20

Aucun de ces écarts n'est un fait établi : ils reposent sur des hypothèses de travail du groupe ou sur des déclarations non prouvées. Les vérifier serait la première étape d'une mission réelle.

4. Atelier 2 - Sources de risque et objectifs visés

Huit couples source de risque / objectif visé ont été évalués en croisant la **motivation** et les **ressources** de chaque attaquant. **Trois sont retenus**, couvrant les trois profils de menace pertinents pour une PME : le crime organisé à but lucratif, la fraude financière et la menace interne.

Source de risque	Objectif visé	Motiv.	Ress.	Pertinence	Retenu
SR1 - Organisation criminelle (rançongiciel)	OV1 - Gain financier : chiffrer l'ERP/CRM et les sauvegardes puis exiger une rançon, avec exfiltration préalable d…	+++	++	Elevée	OUI
SR2 - Organisation criminelle (fraude financière)	OV2 - Gain financier : détourner les paiements clients par fraude au RIB, après compromission d'une messagerie ou…	+++	+	Moyenne	OUI
SR3 - Collaborateur malveillant (commercial sur le départ)	OV3 - Lucratif / avantage personnel : emporter le fichier clients et les tarifs négociés chez un concurrent ou pou…	++	++	Moyenne	OUI
SR4 - Concurrent	OV4 - Espionnage : obtenir le fichier clients et la politique tarifaire de Rhénalis	++	+	Faible	NON
SR5 - Organisation étatique	OV5 - Espionnage ou prépositionnement stratégique	+	+++	Moyenne	NON
SR6 - Activiste	OV6 - Idéologique : nuire à l'image de l'entreprise ou perturber son activité	+	++	Faible	NON
SR7 - Amateur (script-kiddie)	OV7 - Défi / amusement : perturber un service exposé sur Internet	+	+	Faible	NON
SR8 - Collaborateur mécontent (licencié)	OV8 - Vengeance : saboter les données ou l'ERP	++	+	Faible	NON



Cartographie des sources de risque : motivation × ressources, couples retenus en plein.

4.1 Justification des exclusions

- **SR4 Concurrent** : les concurrents régionaux n'ont pas de capacité offensive et s'exposeraient à un risque pénal. Le scénario réaliste passe par un salarié débauché, déjà couvert par SR3.
- **SR5 Organisation étatique** : sa pertinence calculée est moyenne, du fait de ressources maximales, mais la motivation est nulle - Rhénalis n'a ni activité stratégique, ni données sensibles pour un État, ni client sensible. **Exclusion décidée par le groupe**, au-delà du seul résultat de la grille.
- **SR6 Activiste** : aucune activité controversée, donc aucune motivation identifiée.

- **SR7 Amateur** : la plateforme n'est pas exposée publiquement, l'accès se faisant par VPN ; le site vitrine est hors périmètre.
- **SR8 Collaborateur licencié** : droits utilisateur limités, sans accès administrateur. Risque couvert par le socle (retrait des accès au départ, sauvegardes).

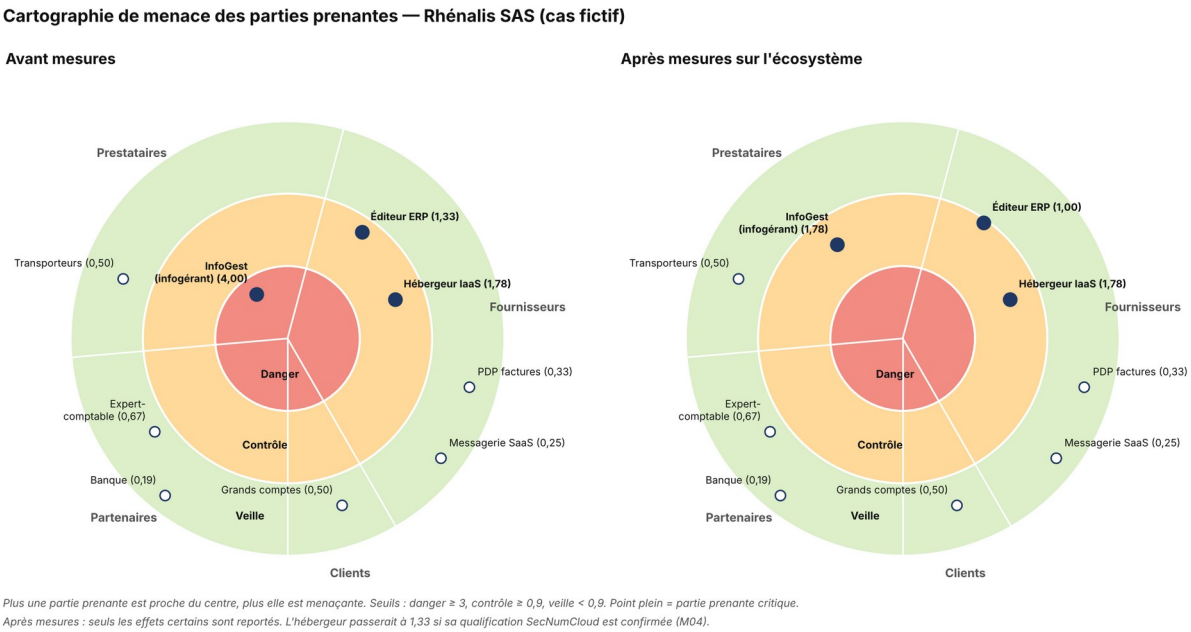
5. Atelier 3 - Écosystème et scénarios stratégiques

5.1 Cotation des parties prenantes

Neuf parties prenantes ont été cotées sur quatre critères : **dépendance** et **pénétration**, qui augmentent la menace, puis **maturité SSI** et **confiance**, qui l'atténuent. L'indice de menace vaut (dépendance × pénétration) ÷ (maturité × confiance).

Partie prenante	Catégorie	Dép.	Pén.	Mat.	Conf.	Indice	Zone
InfoGest Services - infogérant (serveurs, annuaire, sauvegardes)	Prestataire	4	4	2	2	4,00	Danger
Hébergeur IaaS (machines virtuelles, stockage, réseau)	Fournisseur	4	4	3	3	1,78	Contrôle
Éditeur de l'ERP/CRM (mises à jour, télémaintenance)	Fournisseur	4	3	3	3	1,33	Contrôle
Transporteurs (fichiers d'expédition, portail de suivi)	Prestataire	2	1	2	2	0,50	Veille
Cabinet d'expertise comptable (accès distant à la comptabilité)	Partenaire	2	2	2	3	0,67	Veille
Grands comptes (commandes par e-mail et EDI)	Client	3	1	2	3	0,50	Veille
Plateforme de dématérialisation des factures (PDP)	Fournisseur	3	1	3	3	0,33	Veille
Fournisseur de messagerie en ligne (SaaS)	Fournisseur	3	1	4	3	0,25	Veille
Banque (virements, prélèvements, relevés)	Partenaire	3	1	4	4	0,19	Veille

L'infogérant est seul en zone danger (indice 4,00) : relation indispensable et non substituable à court terme, droits d'administration sur l'annuaire, les serveurs et les sauvegardes, mais sécurité réactive et contrat dépourvu de clause de sécurité. Deux parties prenantes sont en zone contrôle (hébergeur et éditeur) et six en veille, soit 11 % en danger, 22 % en contrôle, 67 % en veille et aucune hors périmètre. Cette répartition s'écarte de la règle indicative du guide (10 / 40 / 40 / 10) : une PME compte peu de tiers disposant d'un accès privilégié à son système d'information, ce qui concentre la menace sur l'infogérant.



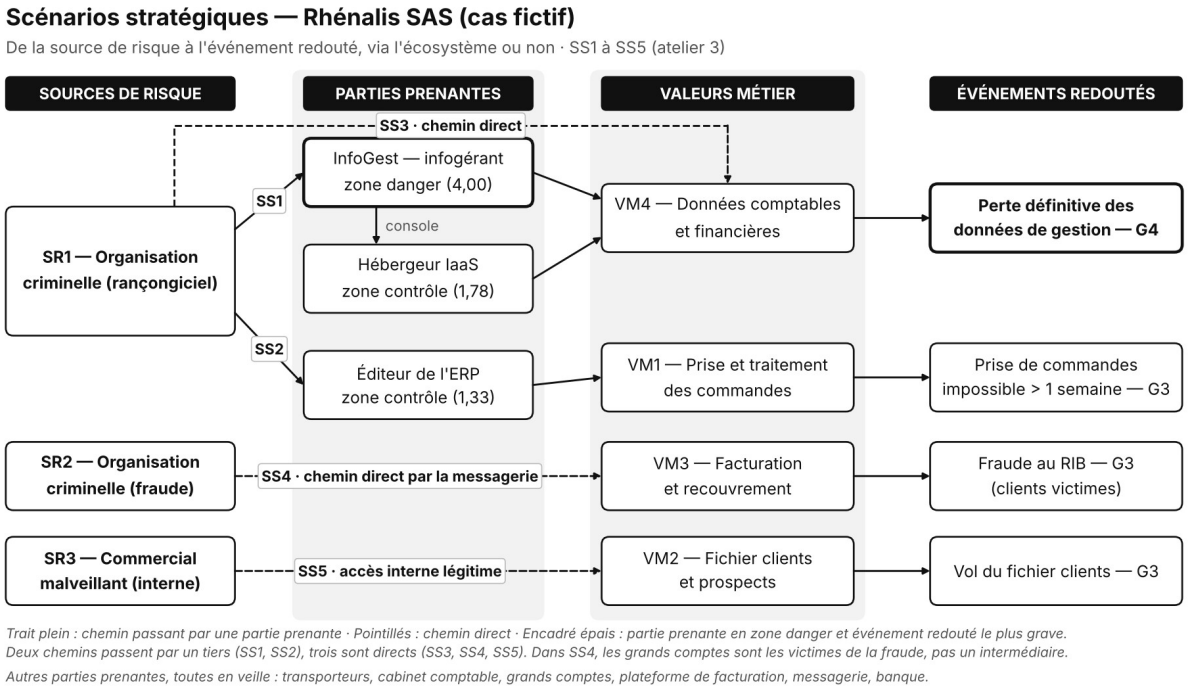
Cartographie de menace des parties prenantes, avant et après les mesures sur l'écosystème.

5.2 Justification des cotations

Partie prenante	Justification de la cotation
InfoGest Services - infogérant	Dép. 4 : seul à administrer la plateforme. Pén. 4 : admin du domaine, des serveurs et des sauvegardes. Mat. 2 : sécurité réactive, compte partagé, pas de MFA (H04, H05). Conf. 2 : contrat sans clause de sécurité (H13).
Hébergeur IaaS	Dép. 4 : héberge toute la plateforme. Pén. 4 : contrôle hyperviseur et stockage. Mat. 3 : politique de sécurité globale supposée (H23), qualification à vérifier (H14). Conf. 3 : relation contractuelle claire.
Éditeur de l'ERP/CRM	Dép. 4 : ERP non substituable à court terme. Pén. 3 : accès admin au serveur d'application en télémaintenance (H17). Mat. 3, Conf. 3 : éditeur établi.
Transporteurs	Dép. 2 : transporteurs substituables. Pén. 1 : échanges de fichiers, aucun accès au SI. Mat. 2 : grands transporteurs nationaux dotés d'une politique de sécurité (H22). Conf. 2 : intentions neutres.
Cabinet d'expertise comptable	Dép. 2 : utile (clôture, déclarations). Pén. 2 : compte distant sur l'ERP en lecture et export (H18). Mat. 2 : petit cabinet, sécurité réactive. Conf. 3 : relation ancienne.
Grands comptes	Dép. 3 : indispensables mais nombreux. Pén. 1 : aucun accès au SI. Mat. 2 : hétérogène. Conf. 3 : intentions positives.
Plateforme de dématérialisation des factures	Dép. 3 : obligatoire pour la facturation électronique. Pén. 1 : échange de flux, pas d'accès. Mat. 3 : plateforme immatriculée par l'État. Conf. 3.
Fournisseur de messagerie en ligne	Dép. 3 : messagerie indispensable. Pén. 1 : pas d'accès à l'ERP. Mat. 4 : grand fournisseur cloud. Conf. 3.
Banque	Dép. 3 : substituable. Pén. 1 : aucun accès au SI. Mat. 4, Conf. 4 : secteur régulé.

5.3 Scénarios stratégiques

Cinq chemins d'attaque stratégiques relient les sources de risque retenues aux valeurs métier, en passant ou non par une partie prenante : deux chemins passent par un tiers (l'infogérant, avec la console de l'hébergeur, et l'éditeur de l'ERP) et trois sont directs. Les chemins détaillés figurent dans la feuille « Atelier 3 - SS » du classeur.



Vue d'ensemble des cinq scénarios stratégiques, de la source de risque à l'événement redouté.

Code	Source de risque	Intermédiaire	Valeur métier visée	Gravité
SS1	SR1 - Crime organisé	Infogérant (zone danger), avec la console de l'hébergeur (zone contrôle)	VM4 - Données comptables	G4

Code	Source de risque	Intermédiaire	Valeur métier visée	Gravité
SS2	SR1 - Crime organisé	Éditeur de l'ERP (zone contrôle)	VM1 - Prise de commandes	G3
SS3	SR1 - Crime organisé	Aucun (chemin direct)	VM4 - Données comptables	G4
SS4	SR2 - Fraude financière	Aucun (messagerie d'un salarié) ; grands comptes victimes	VM3 - Facturation	G3
SS5	SR3 - Commercial interne	Aucun (accès légitime)	VM2 - Fichier clients	G3

Les deux parties prenantes en zone contrôle portent chacune un scénario (hébergeur dans SS1, éditeur dans SS2). Les transporteurs, cotés en maturité 2 car ce sont de grands groupes nationaux dotés d'une politique de sécurité (H22), sont en veille avec un indice de 0,50.

5.4 Mesures sur l'écosystème

Les mesures portant sur les parties prenantes relèvent surtout de la contractualisation : on ne peut pas imposer une configuration technique à un tiers comme on le fait sur ses propres biens supports.

Partie prenante	Critère visé	Mesure	Effet attendu sur l'indice
InfoGest (infogérant)	Maturité, confiance	Avenant de sécurité : MFA, comptes nominatifs, journalisation, notification d'incident sous 24 h, droit d'audit annuel	4,00 → 1,78 : sortie de la zone danger
InfoGest (infogérant)	Pénétration	Accès d'administration via un bastion, sessions enregistrées, suppression du compte partagé	Accès tracé et limité au nécessaire
Hébergeur IaaS	Maturité	Vérifier la qualification (M04), MFA sur la console d'administration (M06), sauvegarde immuable chez un tiers (M15)	1,78 → 1,33 seulement si la qualification SecNumCloud est confirmée ; sinon inchangé
Éditeur de l'ERP	Confiance	Clauses de sécurité au contrat de maintenance ; télémaintenance à la demande, via le bastion, après validation interne (M08)	1,33 → 1,00 (confiance 3 → 4) : reste en contrôle, sous surveillance. La pénétration reste à 3 : les droits d'administration sur le serveur demeurent
Grands comptes	Confiance	Courrier aux grands comptes : Rhénalis ne change jamais de RIB par e-mail (M10)	Indice inchangé, mais vraisemblance de SS4 réduite

6. Atelier 4 - Scénarios opérationnels et vraisemblance

Chaque scénario stratégique est décliné en un scénario opérationnel, structuré selon la séquence d'attaque en quatre phases de la fiche méthode de l'ANSSI : **Connaître, Rentrer, Trouver, Exploiter**. Chaque phase est rattachée aux biens supports concernés. Les actions sont décrites au niveau générique attendu par la méthode : l'objectif de l'atelier est d'estimer la vraisemblance et de situer les mesures, non de documenter un mode opératoire.

6.1 Déroulement des cinq scénarios

Code	Connaître	Rentrer	Trouver	Exploiter
SO1	Reconnaissance externe : identification de l'infogérant et de ses techniciens	Compromission de l'infogérant, puis connexion par son accès distant d'administration	Prise de contrôle de l'annuaire et des serveurs ERP/CRM	Exfiltration des données, chiffrement de l'ERP/CRM, suppression des sauvegardes et instantanés
SO2	Reconnaissance externe : identification de l'éditeur de l'ERP	Compromission de l'éditeur (accès de télémaintenance ou mise à jour piégée)	Accès administrateur au serveur d'application ERP	Chiffrement de l'ERP ; sauvegardes et annuaire non atteints
SO3	Collecte d'informations publiques sur les salariés	Hameçonnage d'un salarié et prise de contrôle de son poste	Élévation de privilèges jusqu'à administrateur du domaine, déplacement vers les serveurs	Chiffrement de l'ERP/CRM et des sauvegardes hébergées sur la même infrastructure
SO4	Identification des comptables et des grands comptes	Compromission d'une boîte de messagerie par hameçonnage	Observation des échanges de facturation	Faux changement de RIB envoyé aux clients, ou modification du RIB dans l'ERP
SO5	Connaissance interne du CRM et des données de valeur	Accès légitime au CRM avec ses propres identifiants	Repérage du fichier clients et des tarifs négociés	Export massif puis sortie des données hors de l'entreprise

Code	Biens supports concernés
SO1	Accès distant d'administration de l'infogérant, annuaire, serveurs d'application, console IaaS, base de données, système de sauvegarde
SO2	Accès de télémaintenance de l'éditeur, serveurs d'application, modules de l'ERP
SO3	Personnel, postes de travail, liaisons VPN, annuaire, serveurs d'application, base de données, système de sauvegarde
SO4	Personnel, messagerie, postes de la comptabilité, module Facturation de l'ERP
SO5	Personnel, application CRM, base de données, portables des commerciaux

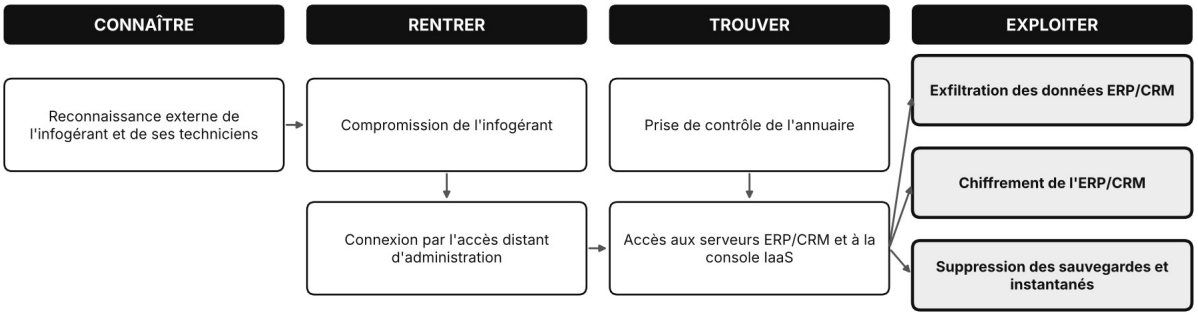
6.2 Graphes d'attaque

Chaque scénario opérationnel est représenté par un graphe en quatre phases. Sous chaque action figure le bien support concerné, tel qu'il est recensé dans la feuille Missions. SO1 est le scénario le plus structurant : il combine la gravité maximale et une vraisemblance élevée, et il correspond au chemin d'attaque cité en exemple dans l'énoncé du TP.

Graphe d'attaque SO1 — Rançongiciel via l'infogérant (SS1, SR1/OV1)

Gravité G4 · Vraisemblance V3 (méthode expresse) · Rhénalis SAS, cas fictif

Encadré épais = objectif atteint



Biens supports :			
—	Accès distant d'administration de l'infogérant	Annuaire, serveurs d'application, console IaaS	Base de données, système de sauvegarde, ERP/CRM

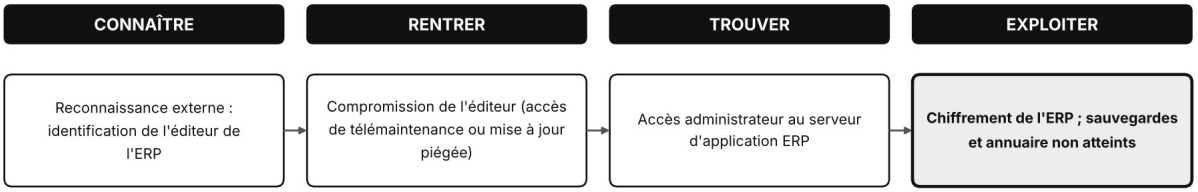
Facteurs favorisants (GAP) : accès d'administration sans MFA (H04), compte admin partagé (H05), pas de supervision (H11), sauvegardes sans copie hors ligne (H08).

Graphe d'attaque de SO1 - rançongiciel via l'infogérant.

Graphe d'attaque SO2 — Rançongiciel via l'éditeur de l'ERP (SS2, SR1/OV1)

Gravité G3 · Vraisemblance V2 (méthode expresse) · Rhénalis SAS, cas fictif

Encadré épais = objectif atteint



Biens supports :			
—	Accès de télémaintenance de l'éditeur	Serveurs d'application ERP/CRM	Modules Ventes et Facturation de l'ERP

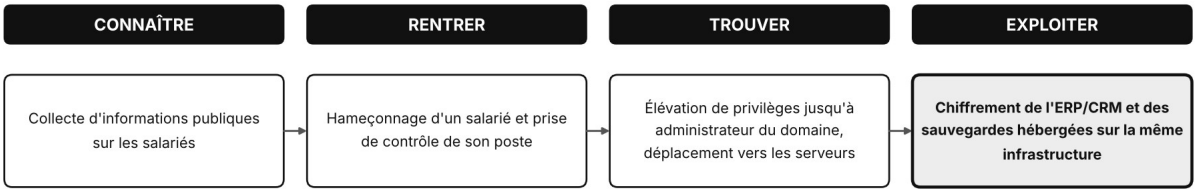
Facteurs favorisants : télémaintenance ouverte sans validation interne (H17). Facteur limitant : l'éditeur, plus mature, doit d'abord être compromis.

Graphe d'attaque de SO2 - rançongiciel via l'éditeur de l'ERP.

Graphe d'attaque SO3 — Rançongiciel via l'hameçonnage d'un salarié (SS3, SR1/OV1)

Gravité G4 · Vraisemblance V3 (méthode expresse) · Rhénalis SAS, cas fictif

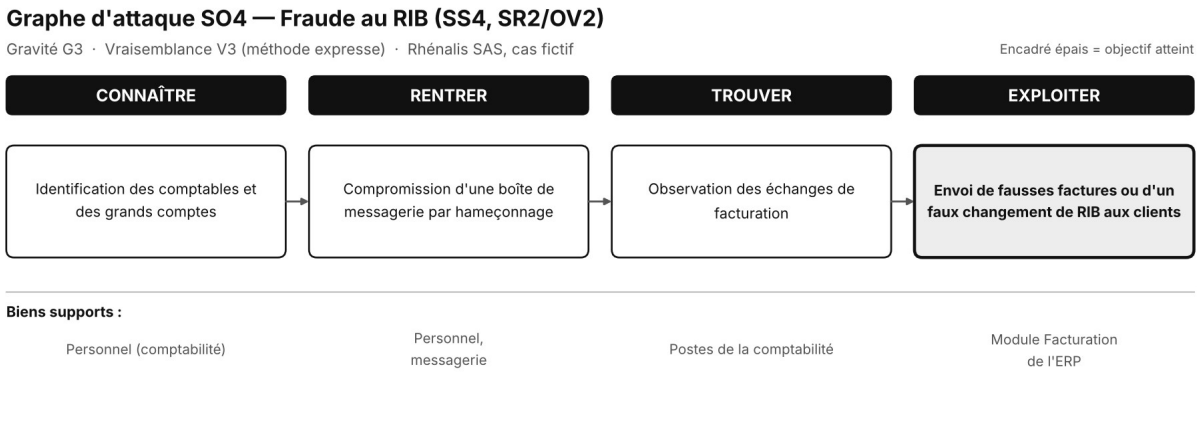
Encadré épais = objectif atteint



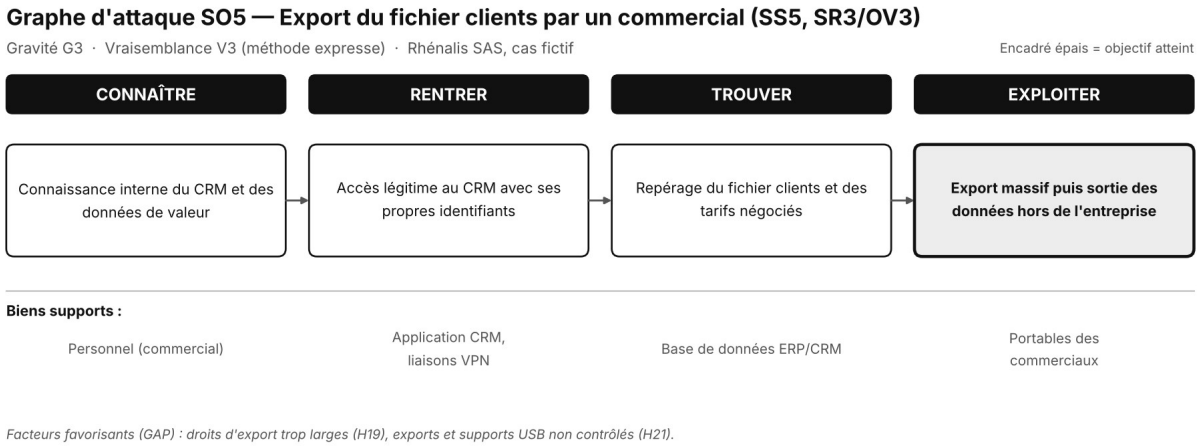
Biens supports :			
Personnel	Personnel, postes de travail (ADV, portables commerciaux)	Annuaire, serveurs d'application	Base de données, système de sauvegarde

Facteurs favorisants (GAP) : pas d'EDR (H09), pas de supervision (H11), sauvegardes sans copie hors ligne (H08), correctifs non vérifiés (H10).

Graphe d'attaque de SO3 - rançongiciel via l'hameçonnage d'un salarié.



Graphe d'attaque de SO4 - fraude au RIB.



Graphe d'attaque de SO5 - export du fichier clients par un commercial.

6.3 Cotation de la vraisemblance

La cotation suit la **méthode expresse** : une vraisemblance globale par scénario, justifiée par les écarts constatés à l'atelier 1 et par le niveau de menace des parties prenantes de l'atelier 3.

Code	Scénario	Vrais.	Justification
SO1	SS1 - rançongiciel via l'infogérant	V3	Accès d'administration sans MFA (H04) et compte administrateur partagé (H05), sans supervision (H11) : hypothèses à vérifier. L'infogérant est en zone danger (indice 4,0).
SO2	SS2 - rançongiciel via l'éditeur de l'ERP	V2	Comme SO1, ce scénario passe par un tiers, mais un tiers mieux protégé : l'éditeur a une maturité de 3 (contre 2 pour l'infogérant) et n'accède au serveur qu'à la demande (H17), alors que l'infogérant dispose d'un accès permanent, sans MFA et avec un compte partagé (H04, H05).
SO3	SS3 - rançongiciel via hameçonnage d'un salarié	V3	~75 utilisateurs exposés, antivirus seul sans EDR (H09), pas de supervision (H11), sauvegardes sans copie hors ligne (H08).
SO4	SS4 - fraude au RIB	V3	Messagerie sans MFA (GAP), aucune vérification des changements de RIB ni information des clients (H20), hameçonnage déjà survenu en 2025 (H15).
SO5	SS5 - export du fichier clients par un commercial	V3	Droits d'export trop larges et aucun contrôle des exports (GAP, H19, H21). Cotation faite en supposant que le commercial passe à l'acte, comme le veut la méthode : une fois décidé, il réussit presque à coup sûr.

Aucun scénario n'est coté V4. Comme le veut la méthode, chaque vraisemblance est évaluée en supposant que la source de risque passe à l'acte ; c'est pourquoi SO5 est coté V3 : un commercial décidé dispose déjà de tous les accès nécessaires. SO1 et SO2 passent tous deux par un tiers, mais l'écart de cotation tient à ce tiers : l'infogérant (maturité 2) dispose d'un accès permanent sans MFA et d'un compte partagé, alors que l'éditeur (maturité 3) n'accède au serveur qu'à la demande (H17). D'où V3 pour SO1 et V2 pour SO2.

7. Atelier 5 - Traitement du risque

7.1 Synthèse des risques

Risque	SR	OV	Événement redouté	SS	G	SO	V	Niveau	Traitement
R1	SR1	OV1	Perte définitive des données comptables (G4)	SS1	4	SO1	3	Elevé	Réduire
R2	SR1	OV1	Prise de commandes impossible > 1 semaine (G3)	SS2	3	SO2	2	Modéré	Réduire
R3	SR1	OV1	Perte définitive des données comptables (G4)	SS3	4	SO3	3	Elevé	Réduire
R4	SR2	OV2	Modification frauduleuse du RIB (G3)	SS4	3	SO4	3	Modéré	Réduire
R5	SR3	OV3	Vol et divulgation du fichier clients (G3)	SS5	3	SO5	3	Modéré	Réduire

Les cinq risques sont traités en **réduction**. Aucun n'est accepté en l'état : les deux risques élevés engagent la continuité de l'activité, et les trois risques modérés portent sur des pertes financières ou des données personnelles. Aucun ne peut être évité, puisque la plateforme ERP/CRM est indispensable à l'activité, et le transfert (cyber-assurance) n'est envisagé qu'en complément, pour la part financière résiduelle.

7.2 Plan de traitement du risque

Les 19 actions sont réparties selon les quatre groupes de la défense en profondeur. Chacune porte un propriétaire nommé, une complexité, un délai, une échéance, un coût estimé et un indicateur de réalisation. Les priorités vont de P1, le plus urgent, à P3.

Gouvernance - 6 actions

N°	Mesure	Risques	Propriétaire	Complexité / délai	Échéance	Coût [H]	Indicateur	Prio
M10	Courrier aux grands comptes : Rhénalis ne change jamais de RIB par e-mail ; en cas de doute, rappeler le numéro habituel	R4	Thomas Weber (DAF)	Faible 1 mois	30/11/2026	0 €	% des grands comptes informés (cible 100 %)	P1
M04	Vérifier la qualification de l'hébergeur IaaS et les clauses de sécurité du contrat d'hébergement	R1	Thomas Weber (DAF)	Faible 2 mois	31/12/2026	0 €	Rapport de vérification remis	P2
M01	Avenant sécurité au contrat d'infogérance : MFA, comptes nominatifs, journalisation, correctifs des serveurs sous 30 jours, notification d'incident sous 24 h, droit d'audit annuel	R1	Thomas Weber (DAF)	Moyenne 3 mois	31/01/2027	2 k€ (juridique)	Avenant signé	P1
M05	Sensibilisation des salariés à l'hameçonnage et campagne d'exercice semestrielle	R3 R4	Sophie Haas (resp. informatique)	Faible 3 mois	31/01/2027	3 k€/an	Taux de clic aux exercices < 10 %	P1
M03	Mise à jour du registre RGPD et procédure de notification à la CNIL sous 72 h	R5	Thomas Weber (DAF)	Faible 3 mois	31/01/2027	0 €	Registre à jour, procédure validée	P2
M02	Rédiger une PSSI simplifiée et désigner formellement un référent sécurité	Tous	Claire Muller (DG)	Moyenne 6 mois	30/04/2027	Interne (~15 j)	PSSI validée en comité de direction	P2

Protection - 7 actions

N°	Mesure	Risques	Propriétaire	Complexité / délai	Échéance	Coût [H]	Indicateur	Prio
M18	Double validation par le DAF de toute modification de RIB dans l'ERP (clients et fournisseurs), avec traçabilité	R4	Thomas Weber (DAF)	Faible 1 mois	30/11/2026	0 €	100 % des RIB modifiés validés par le DAF	P1
M06	Authentification multifacteur sur tous les accès distants (administration, VPN nomades), sur la console d'administration IaaS et sur la messagerie	R1 R3 R4	Sophie Haas (resp. informatique)	Moyenne 2 mois	31/12/2026	4 k€/an	% de comptes protégés par MFA (cible 100 %)	P1
M09	Restreindre l'export du CRM à la direction commerciale, revue trimestrielle des droits, blocage des supports USB sur les portables	R5	Julien Roth (dir. commercial)	Faible 2 mois	31/12/2026	1 k€	Revue des droits faite chaque trimestre	P1
M07	Bastion d'administration avec comptes nominatifs et enregistrement des sessions ; suppression du compte admin partagé	R1 R2	Sophie Haas (pilotage) / InfoGest	Élevée 6 mois	30/04/2027	15 k€ + 5 k€/an	Aucun compte admin partagé actif	P1
M19	Vérifier chaque mois l'application des correctifs sur les postes (export de la console de mise à jour)	R3	Sophie Haas (resp. informatique)	Faible 2 mois	31/12/2026	0 €	% de postes à jour depuis moins de 30 jours (cible ≥ 95 %)	P2
M08	Télémaintenance de l'éditeur ouverte uniquement à la demande, via le bastion, après validation interne	R2	Sophie Haas (resp. informatique)	Faible 7 mois	31/05/2027	0 €	100 % des sessions validées et enregistrées	P2
M11	Durcissement de l'annuaire : séparation des comptes d'administration, mots de passe admin uniques	R1 R3	InfoGest (pilotage Sophie Haas)	Élevée 9 mois	31/07/2027	8 k€	Audit annuaire sans écart critique	P2

Défense - 3 actions

N°	Mesure	Risques	Propriétaire	Complexité / délai	Échéance	Coût [H]	Indicateur	Prio
M12	Déployer une solution de détection et réponse (EDR) sur les postes et les serveurs	R3	Sophie Haas (resp. informatique)	Moyenne 4 mois	28/02/2027	8 k€/an	% du parc couvert (cible 100 %)	P1
M14	Alerte automatique sur les exports volumineux du CRM	R5	Sophie Haas (resp. informatique)	Moyenne 6 mois	30/04/2027	2 k€	Alerte testée et opérationnelle	P3
M13	Journalisation centralisée et supervision externalisée (SOC managé) des accès d'administration et de l'annuaire	R1 R3	Sophie Haas (resp. informatique)	Élevée 9 mois	31/07/2027	20 k€/an	Délai de détection d'un accès admin anormal < 24 h	P2

Résilience - 3 actions

N°	Mesure	Risques	Propriétaire	Complexité / délai	Échéance	Coût [H]	Indicateur	Prio
M15	Sauvegarde immuable externalisée chez un tiers distinct de l'infogérant, test de restauration trimestriel	R1 R2 R3	Sophie Haas (resp. informatique)	Moyenne 3 mois	31/01/2027	6 k€/an	Test de restauration réussi chaque trimestre	P1
M17	Étudier une cyber-assurance pour transférer le risque financier résiduel	R1 R4	Thomas Weber (DAF)	Faible 6 mois	30/04/2027	5 à 10 k€/an	Décision de la direction	P3
M16	Plan de continuité et de reprise de l'ERP (mode dégradé documenté) et exercice de crise annuel	R1 R2 R3	Claire Muller (DG)	Élevée 12 mois	31/10/2027	5 k€	Exercice de crise réalisé, reprise < 48 h	P2

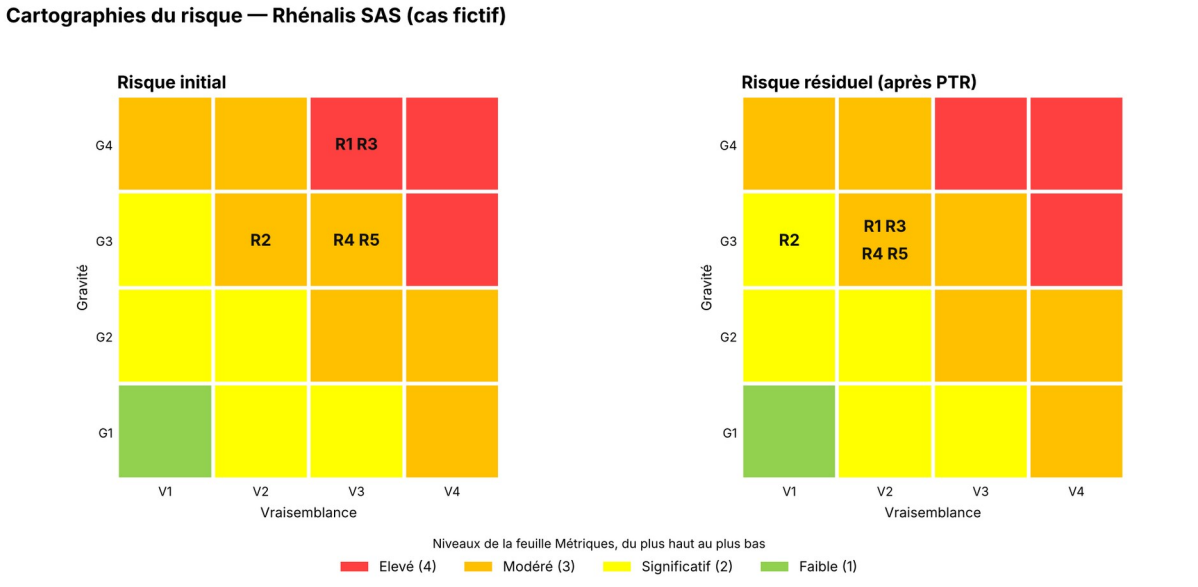
*Les coûts sont des ordres de grandeur **[H]**, destinés à permettre un arbitrage de la direction ; ils devraient être confirmés par devis.*

7.3 Risques résiduels

Les niveaux résiduels sont estimés en supposant les mesures du plan réalisées. La baisse vient surtout de la vraisemblance : les mesures réduisent la facilité d'exécution des scénarios plus qu'elles ne réduisent l'impact métier.

Risque	G init.	V init.	Niveau initial	Mesures	G rés.	V rés.	Niveau résiduel
R1	G4	V3	Elevé	M01 M04 M06 M07 M11 M13 M15 M16 M17	G3	V2	Modéré
R2	G3	V2	Modéré	M07 M08 M15 M16	G3	V1	Significatif
R3	G4	V3	Elevé	M05 M06 M11 M12 M13 M15 M16 M19	G3	V2	Modéré
R4	G3	V3	Modéré	M05 M06 M10 M17 M18	G3	V2	Modéré
R5	G3	V3	Modéré	M03 M09 M14	G3	V2	Modéré

R1 et R3 passent de G4 à G3 : avec une sauvegarde immuable testée (M15), la perte définitive des données n'est plus atteignable ; il reste l'indisponibilité de l'ERP et l'exfiltration de données. **R4 reste modéré** : le courrier aux grands comptes (M10) et la double validation des RIB (M18) réduisent la vraisemblance à V2 sans la supprimer, car c'est le client qui effectue le paiement. **R5 reste modéré** : un commercial conserve un accès légitime au CRM ; seules la détection et la dissuasion progressent. Ces risques résiduels modérés (R1, R3, R4, R5) doivent être explicitement acceptés par la direction.



Cartographies du risque initial et du risque résiduel après mise en œuvre du plan.

7.4 Cadre de suivi

Indicateur	Mesure liée	Cible	Fréquence	Responsable
% de comptes à privilèges et d'accès distants protégés par MFA	M06	100 %	Mensuelle	Sophie Haas
Tests de restauration réussis	M15	4 par an	Trimestrielle	Sophie Haas
Taux de clic aux exercices d'hameçonnage	M05	< 10 %	Semestrielle	Sophie Haas
Comptes administrateurs partagés encore actifs	M07	0	Mensuelle	InfoGest / Sophie Haas
Avancement du PTR (actions terminées / prévues)	Toutes	100 % au 31/10/2027	Trimestrielle	Claire Muller
RIB modifiés dans l'ERP validés par le DAF	M18	100 %	Mensuelle	Thomas Weber
Grands comptes informés de la procédure RIB	M10	100 %	Annuelle	Thomas Weber
Postes à jour des correctifs depuis moins de 30 jours	M19	≥ 95 %	Mensuelle	Sophie Haas

- **Comité sécurité trimestriel** réunissant la DG, le DAF, la responsable informatique et l'infogérant : avancement du plan et revue des indicateurs.
- **Revue du cycle opérationnel** (atelier 4 et plan de traitement) : annuelle, ou après tout incident significatif.
- **Revue du cycle stratégique** (ateliers 1, 2, 3 et 5) : tous les trois ans, ou en cas de changement d'ERP, d'infogérant ou d'hébergeur.
- **Prochaine revue complète** : octobre 2027.

8. Limites de l’analyse

Signaler les limites fait partie de la rigueur attendue : les conclusions ci-dessus ne valent que dans le cadre posé.

- **Le cas est fictif.** Hormis l’objet d’étude et ses composants, donnés par l’énoncé, tout repose sur les 23 hypothèses du journal en annexe. Aucune n’a été vérifiée auprès d’un interlocuteur réel.
- **Les écarts de sécurité sont supposés, non audités.** Les vérifier - tests de restauration, configuration des accès distants, revue des droits du CRM - serait la première étape d’une mission réelle, et pourrait modifier les vraisemblances.
- **La vraisemblance a été cotée en méthode expresse**, scénario par scénario. Une cotation action par action (méthode standard) donnerait un résultat plus fin, en particulier pour les chaînes longues.
- **Les coûts et les délais sont des ordres de grandeur**, non des devis. Le budget présenté sert à situer l’effort, pas à engager la dépense.
- **Deux informations manquent** et bloquent une conclusion ferme : le dernier compte rendu de test de restauration (H07) et le niveau de qualification de l’hébergeur (H14). La cotation de R1 dépend directement de la première.
- **Le périmètre exclut** la paie, le site vitrine et les équipements d’entrepôt. La messagerie est étudiée comme bien support de VM1 et VM3, mais pas l’infrastructure interne de son fournisseur, sur laquelle Rhénalis n’a pas de prise directe.

Annexe A - Journal d'hypothèses

Ce journal recense tout ce que le groupe a ajouté au cas fourni. Il est tenu à jour depuis le cadrage et conditionne la lecture de l'ensemble du dossier.

N°	Élément	Statut	Justification	Utilisé dans	À vérifier auprès de
H01	PME de 90 salariés, distribution B2B, 22 M€ de CA	[H]	Profil type d'une PME dépendante d'un ERP	A1 (gravité)	Groupe
H02	L'ERP est indispensable : sans lui, ni commande ni facturation	[H]	Activité de distribution entièrement informatisée	A1 - ER	Directeur commercial
H03	Le personnel peut tenir 1 journée en mode dégradé (papier, téléphone), pas davantage	[H]	Déclaration à recueillir auprès du directeur commercial	A1 - ER (disponibilité)	Directeur commercial
H04	L'infogérant accède aux serveurs par VPN sans authentification multifacteur	[H]	Situation fréquente dans les PME ; scénario cité en exemple par le sujet	A1 - GAP, A3, A4	InfoGest Services
H05	L'infogérant utilise un compte administrateur de domaine partagé entre ses techniciens	[H]	Pratique courante, non tracée	A1 - GAP, A4	InfoGest Services
H06	Les sauvegardes sont réalisées tous les jours	[H]	Déclaration à recueillir auprès de l'infogérant, puis à prouver	A1 - GAP, A4	Rapports de sauvegarde
H07	Aucun test de restauration documenté	[M]	Dernier compte rendu de test non disponible	A1 - GAP, A5	InfoGest Services
H08	Sauvegardes sur la même infrastructure que la production, sans copie hors ligne	[H]	À confirmer ; détermine l'impact d'un rançongiciel	A4 (vraisemblance)	InfoGest Services
H09	Antivirus classique sur les postes, pas d'EDR	[H]	Budget sécurité limité	A1 - GAP, A4	Responsable informatique
H10	Correctifs des postes appliqués chaque mois par le technicien interne	[H]	Déclaration à recueillir auprès du responsable informatique	A1 - GAP, A5 (M19)	Console de gestion des mises à jour
H11	Pas de journalisation centralisée ni de supervision de sécurité	[H]	Aucun SIEM ni SOC mentionné	A1 - GAP, A4	Responsable informatique
H12	Pas de PSSI formalisée ni de plan de continuité (PCA/PRA)	[H]	Maturité SSI faible, typique d'une PME	A1 - GAP, A5	Direction
H13	Le contrat d'infogérance ne contient ni clause de sécurité, ni droit d'audit, ni délai de notification d'incident	[H]	Contrat ancien, centré sur la disponibilité	A3 - PP, A5	DAF (contrat)
H14	Niveau de qualification de l'hébergeur IaaS (SecNumCloud ou non)	[M]	Inconnu à ce stade	A3 - PP	Contrat d'hébergement
H15	Hameçonnage réussi sur la messagerie d'un commercial en 2025	[H]	Incident inventé pour illustrer la menace	A2, A4	Responsable informatique
H16	Registre RGPD incomplet pour le CRM	[H]	Fréquent dans les PME	A1 - GAP	DAF
H17	L'éditeur de l'ERP/CRM se connecte ponctuellement au serveur d'application pour la télémaintenance, avec des droits d'administration	[H]	Pratique courante pour le support d'un ERP ; justifie la pénétration 3 de l'éditeur	A3 - PP, A3 - SS (SS2), A4	Contrat de maintenance de l'éditeur
H18	Le cabinet d'expertise comptable dispose d'un compte distant sur l'ERP, en lecture et export de la comptabilité	[H]	Usage fréquent pour la clôture et les déclarations ; justifie la pénétration 2 du cabinet	A3 - PP	DAF

N°	Élément	Statut	Justification	Utilisé dans	À vérifier auprès de
H19	Droits du CRM trop larges : tous les commerciaux peuvent exporter l'intégralité du fichier clients	[H]	Paramétrage par défaut fréquent, jamais revu	A1 - GAP, A4 (SO5)	Administrateur du CRM
H20	Aucune procédure de vérification des changements de RIB (ni contre-appel, ni double validation) ; clients jamais informés	[H]	Pratique courante dans les PME	A1 - GAP, A4 (SO4), A5	DAF
H21	Exports du CRM et supports USB non contrôlés sur les portables	[H]	Aucune solution de prévention des fuites mentionnée	A1 - GAP, A4 (SO5)	Responsable informatique
H22	Les transporteurs sont des groupes nationaux qui appliquent les règles d'hygiène et la réglementation, avec une sécurité réactive	[H]	Profil des principaux transporteurs de messagerie express ; justifie leur maturité 2	A3 - PP	Contrats de transport
H23	L'hébergeur IaaS applique une politique de sécurité globale, sans que sa qualification soit connue (H14)	[H]	Niveau courant pour un hébergeur professionnel ; justifie sa maturité 3, à confirmer	A3 - PP	Contrat d'hébergement, certifications

Formule utile en restitution : « Faute d'information sur X, nous avons retenu l'hypothèse Y ; si elle se révèle fausse, la cotation du risque Rn passerait de A à B. »

Annexe B - Correspondance avec le classeur

Chaque partie de ce dossier renvoie à une feuille du classeur EBIOS RM remis en parallèle.

Partie du dossier	Feuille du classeur
2. Cadrage, périmètre et méthode	Organisation, Métriques
3.1 Valeurs métier et biens supports	Atelier 1 - Missions
3.2 Événements redoutés	Atelier 1 - ER
3.3 Socle de sécurité	Atelier 1 - GAP
4. Sources de risque	Atelier 2 - SROV
4. Cartographie des sources de risque	Atelier 2 - SROV (image sous le tableau)
5.1 et 5.2 Parties prenantes et justification des cotations	Atelier 3 - PP (colonne J), Atelier 3 - Carto PP
5.3 Scénarios stratégiques	Atelier 3 - SS, Atelier 3 - SS1
5.4 Mesures sur l'écosystème	Dossier uniquement (reprises dans le PTR : M01, M04, M06, M07, M08, M10, M15)
6. Scénarios opérationnels	Atelier 4 - SO, Atelier 4 - SO1
7.1 Synthèse des risques	Atelier 5 - Risques
7.2 Plan de traitement	PTR
7.3 Risques résiduels	Risques résiduels
7.4 Cadre de suivi	Cadre de suivi

Référentiels utilisés : guide EBIOS Risk Manager de l'ANSSI et fiches méthodes des ateliers 1 à 5 ; guide d'hygiène informatique de l'ANSSI ; règlement général sur la protection des données (RGPD).